

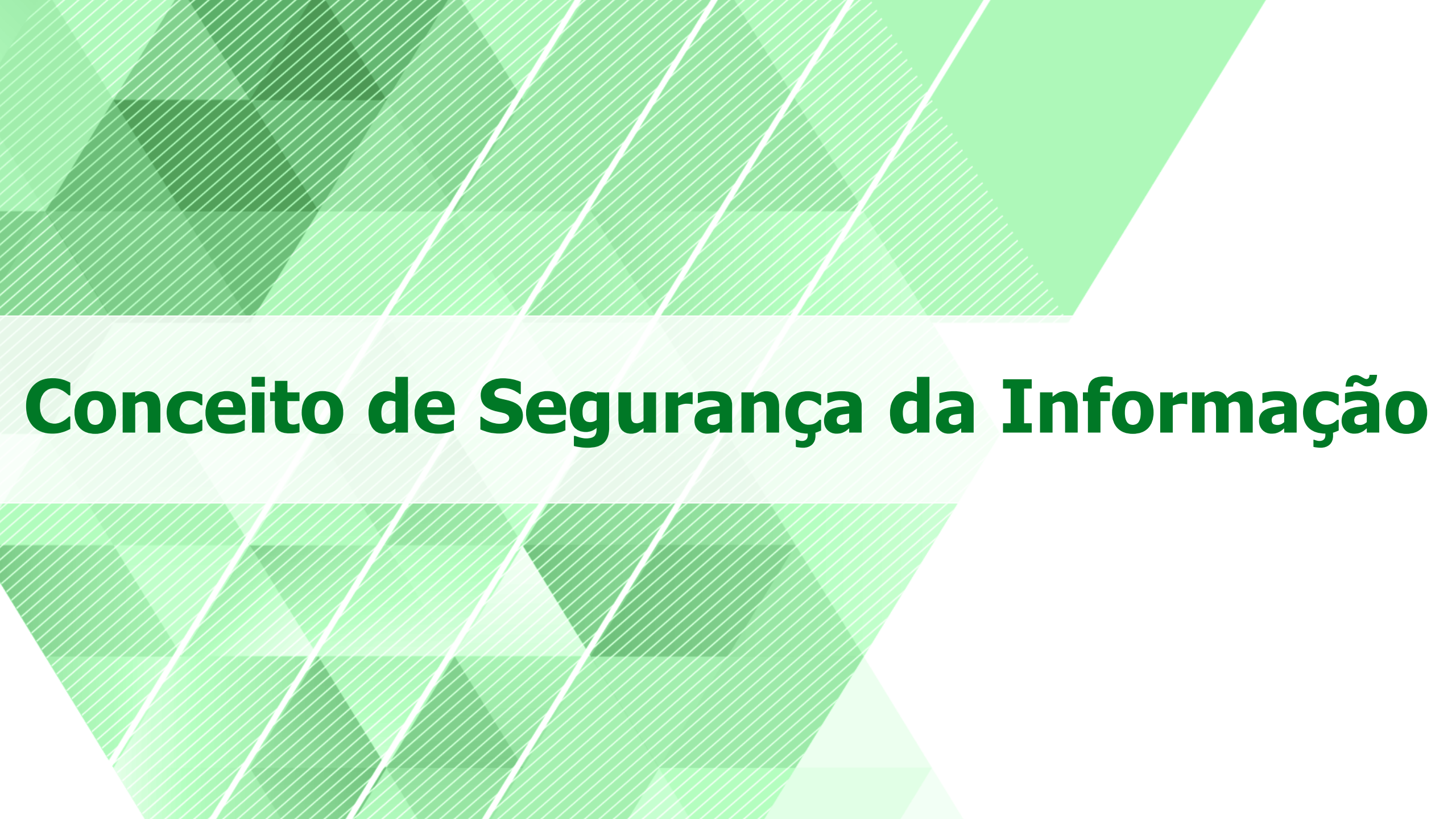
Segurança da Informação (S.I.)

Revisão para P1

Prof. Me. Euclides Nasorri Gottsfritz
euclides.gottsfritz@ifsp.edu.br



INSTITUTO FEDERAL
São Paulo
Campus Catanduva



Conceito de Segurança da Informação

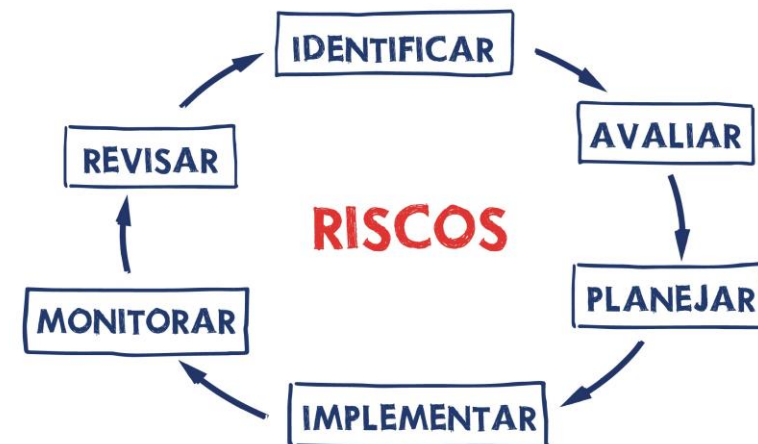
Conceito de Segurança da Informação

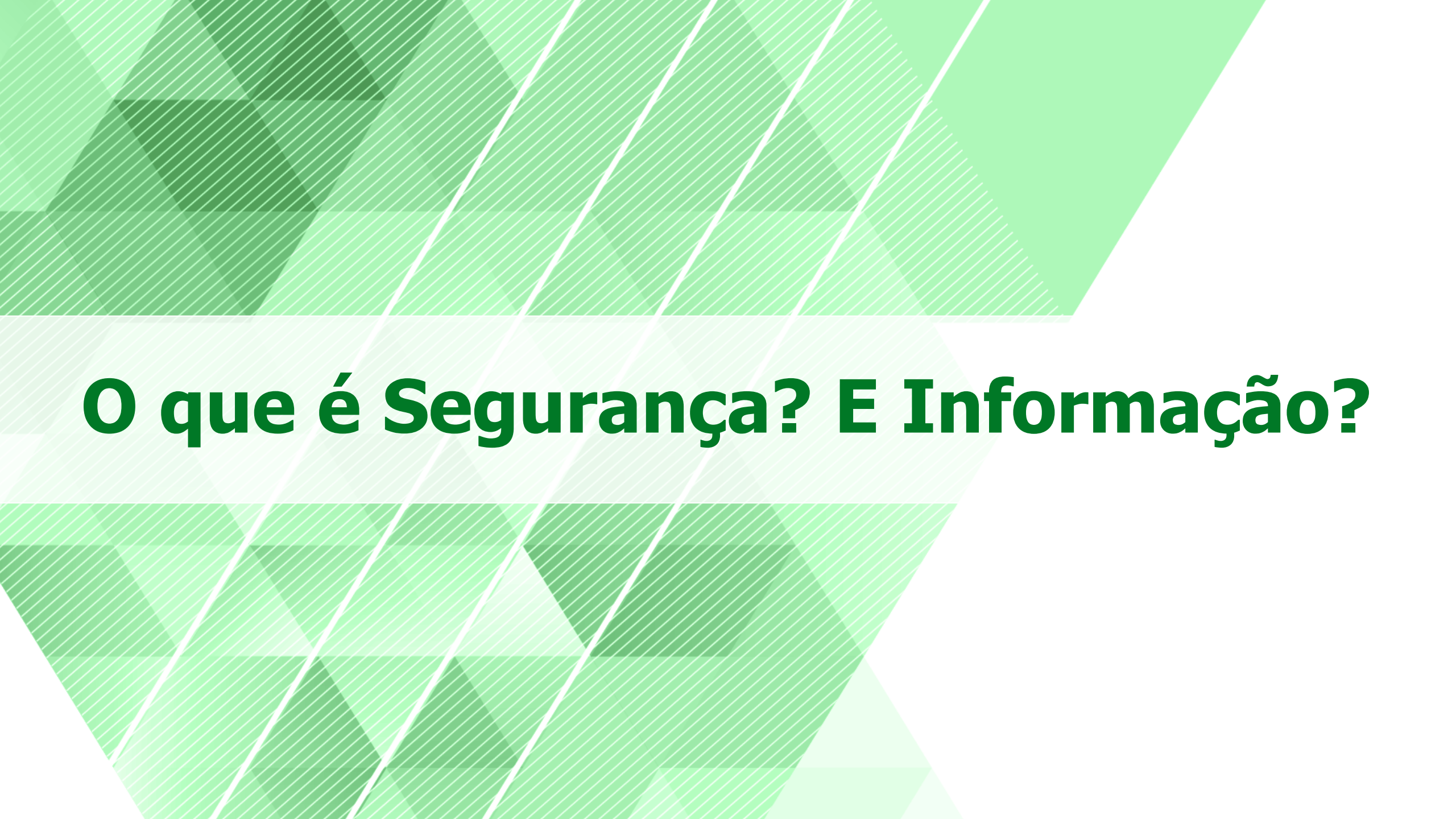
- Problemas de Segurança não são apenas indisponibilidade de serviços online;
- É obvio que uma rede paralisada causa prejuízos, porém dados vazados ou até mesmo perdidos podem causar prejuízos ainda maiores;
- Logo, é obrigação do técnico, consultor, administrador ou gestor de T.I. cuidar para que os negócios da empresa tenham continuidade;
- Essa continuidade se faz através do conhecimento dos riscos, antecipação dos problemas e implementação de soluções para mitigar o(s) problema(s);



Conceito de Segurança da Informação

- **Antigamente**, ao se falar em Segurança da Informação, o seu **foco era resolver os problemas** conforme eles aparecerem;
- Porém com a celeridade que a tecnologia avança e as coisas acontecem, **isso não é mais viável**;
- Logo, é necessário que o **profissional de T.I.** haja de forma **(pro)ativa**, antecipando e **corrigindo o problema antes de sua exploração**;
- Outro recurso necessário na atualidade se chama “**Plano de Contingência**”, nele deverá haver **diretrizes para conter o problema** e tornar o seu impacto o menor possível;





O que é Segurança? E Informação?

O que é Segurança?

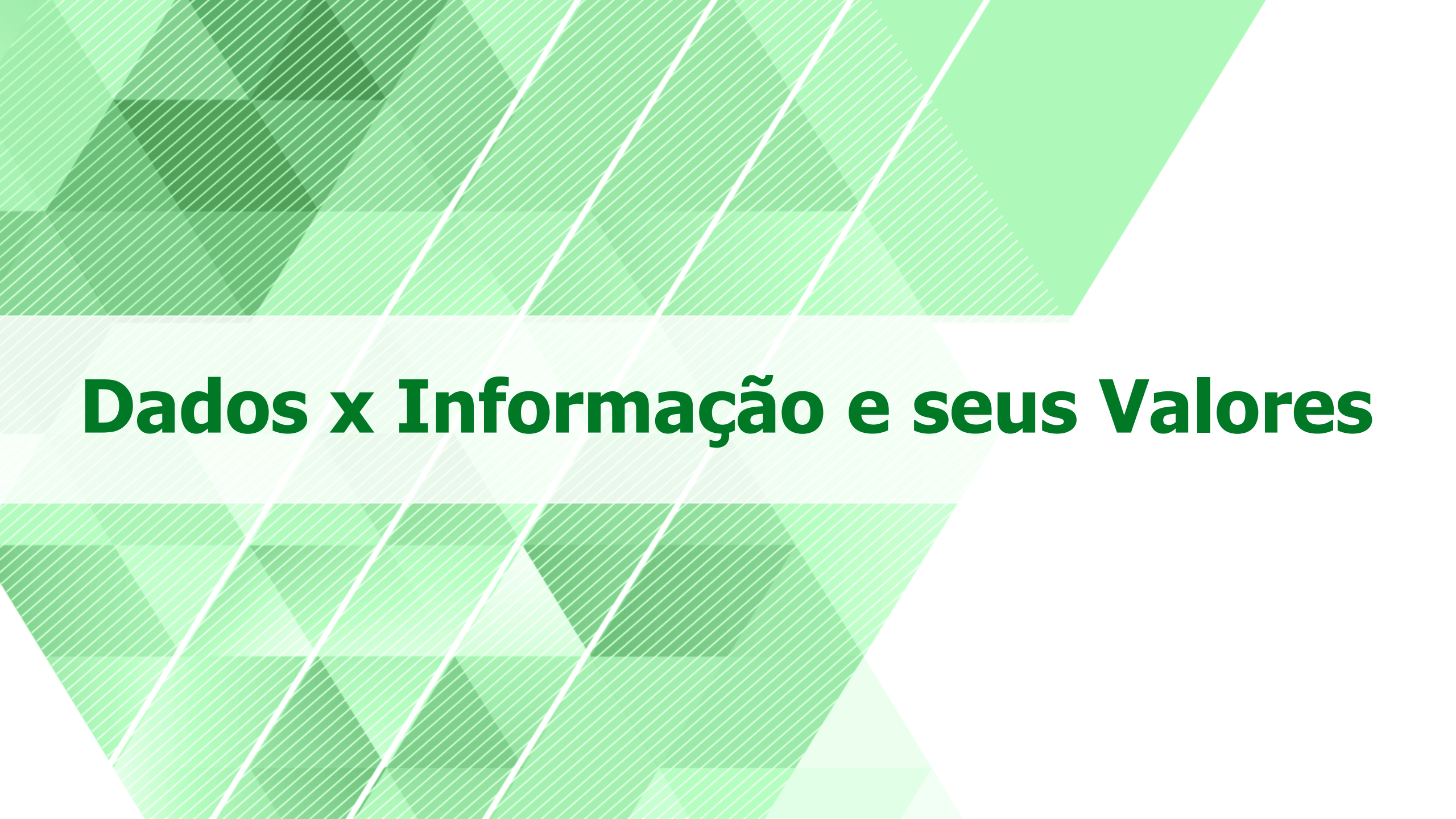
- A resposta está no **Slide 14**, lembrem das palavras “**SEVERIDADE**” e “**RAMO DE ATUAÇÃO**”?
- Vamos descontextualizar:
 - Imaginem que **vocês são multimilionários** do petróleo e estão a **passeio no Rio de Janeiro** (sem preconceitos). Vocês possuem a capacidade de contratar qualquer tipo e quantidade de segurança, **quais as opções de vocês?**



O que é Segurança?

- A resposta está no Slide 27, lembrem das palavras “**SEVERIDADE**” e “**RAMO DE ATUAÇÃO**”?
- Vamos descontextualizar:
 - Agora vocês vão **à trabalho** visitar poços de petróleo no exterior, como **West Qurna** e **Rumalia** no Iraque. **Quais suas opções de segurança?**

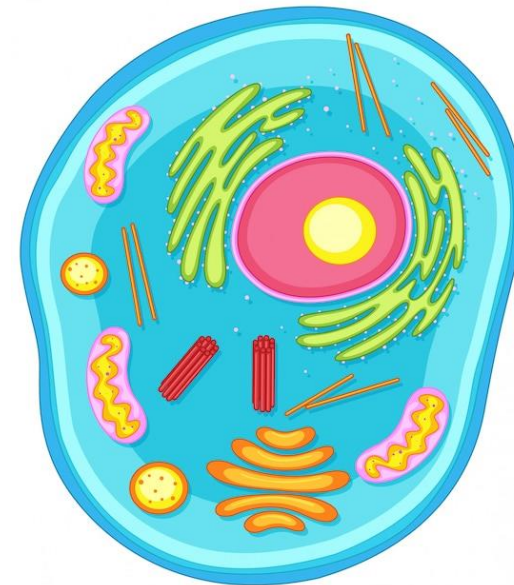
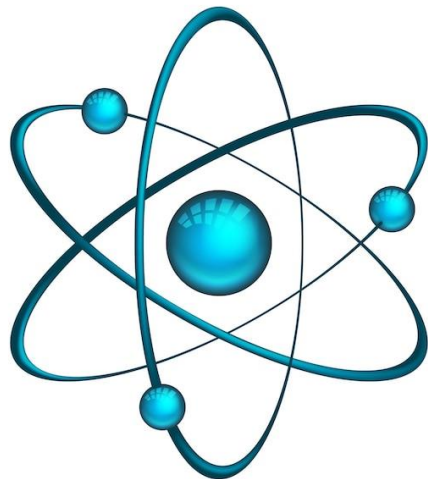




Dados x Informação e seus Valores

Dados x Informação e seus Valores

- “Dado” é TUDO o que possui registro, inclusive um átomo;
 - Ex: o corpo humano pode ser considerado uma Informação, assim como as células que o compõe são os Dados. É interessante lembrar que o corpo humano inicia com apenas 1 célula, que possui todas as diretrizes para compor um corpo completo com o tempo.



Dados x Informação e seus Valores

- As informações são extraídas de Dados, porém esse processo exige Conhecimento e Equipamento;
 - Ex: **Constelações**. Alguém aqui na sala consegue olhar para o céu e identificar a Constelação de Andrômeda? Se sim é porque você possui o Conhecimento e Equipamento para isso.



Dados x Informação e seus Valores

- **Dados -> Informações -> Conhecimento -> Inteligência;**
- **Exemplo de Dado:** 25,3% - 213 Milhões;
- **Exemplo de Informação:** a população brasileira é de 213 milhões de pessoas, onde 25,3% não possuem acesso à Internet;
- **Exemplo de Conhecimento:** no Brasil há cerca de 53 milhões de pessoas com dificuldade de fazer autoatendimento no serviço público online;
- **Exemplo de Inteligência:** realização de políticas públicas de inclusão digital através da doação de equipamentos eletrônicos ou até mesmo instalação de terminais de acesso em departamentos públicos para uso da população;



Dados x Informação e seus Valores

- “O **Valor da Informação** vai além de palavras, escritas, números e imagens: **Conhecimentos**, **Conceitos**, **Ideias** e **Marcas** são exemplo de formas intangíveis de informação. Em um mundo interconectado informação e outros ativos associados merecem ou requerem proteção contra várias fontes de risco, sejam **Naturais**, **Acidentais** ou **Deliberadas**.” (ABNT NBR ISO/IEC 27002:2022, p. ix)





Ativos

Ativos

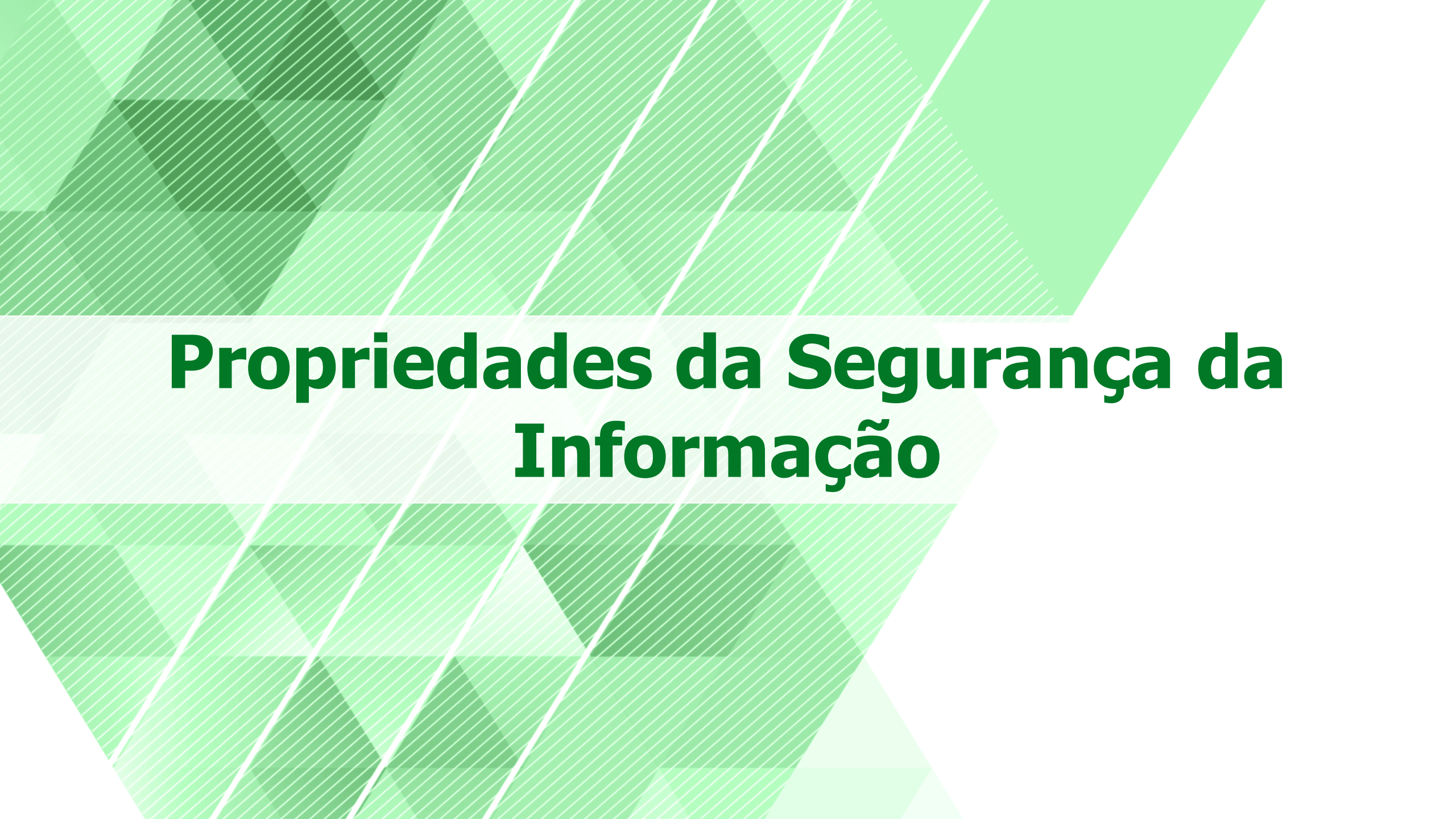


- Segundo a ISO 27002:2022:
 - “**Ativo** é qualquer elemento com valor para a organização e que necessite de proteção.”
- Ou seja, tudo o que possui valor para a empresa e precisam ser protegidos para que o negócio da empresa não seja prejudicado;
- Normalmente, em T.I. os ativos são informações, o que dá suporte às informações e as pessoas;
- A ISO 27005:2023 também alerta que o Levantamento e Reconhecimento dos ativos faz parte do Processo de Identificação de Riscos da Empresa;

Ativos



- Para **planejarmos toda Segurança da Informação**, devemos inicialmente **Inventariar os Ativos** envolvidos, ou seja, **classifica-los** nas categorias que acabamos de ver:
 - **Informações:** todos os tipos de Informações, sejam elas físicas ou digitais.
Ex: Cartas, documentos, registros, armazenamentos, arquivos de configuração, etc;
 - **Equipamentos:** todos os equipamentos que dão suporte à informação durante o seu uso, tráfego e armazenamento. **Ex:** estações de trabalho, servidores, switches, roteadores, discos de backup ,etc;
 - **Aplicações:** softwares da empresa. **Ex:** Sistema Operacional, Banco de Dados, sistema de e-mail, ERPs, etc;
 - **Usuários:** todos que tenham contato com os ativos da empresa. **Ex:** estagiários, funcionários terceirizados, fornecedores, etc.
- Ou seja, **“A Informação, seu Emissor, o meio no qual trafega, Armazenamento, até o seu Receptor.”**



Propriedades da Segurança da Informação

Propriedades da Segurança da Informação

- E também **3 (três) propriedades primordiais** na Segurança da Informação:
 - **Confidencialidade:** É a necessidade de garantir que as informações sejam divulgadas somente àqueles que possuem autorização para tal. **Ex:** Uma pessoa não autorizada também consegue acesso ao seu computador e consegue ler toda a sua Declaração de Imposto de Renda;
 - **Integridade:** É a necessidade de garantir que as informações não tenham sido alteradas accidental ou deliberadamente, estando elas completas e corretas. **Ex:** Uma pessoa não autorizada acessa o seu computador e altera sua Declaração de Imposto de Renda antes de você enviá-la;
 - **Disponibilidade:** É a necessidade de garantir que os propósitos de um sistema possam ser atingidos e que ele esteja acessível àqueles que dele precisam. **Ex:** O seu provedor de internet sofre uma sobrecarga de dados intencional o que causa uma indisponibilidade de internet para você, impossibilitando o envio da sua Declaração de Imposto de Renda.



Riscos

O que são Riscos?

MICHAELIS

Português

Inglês

Espanhol

Alemão

Italiano

Dicionário Brasileiro da Língua Portuguesa

Sobre o dicionário Como consultar ▾ Noções gramaticais ▾ Créditos

Português Brasileiro ▾ Digite o termo desejado

risco²

ris·co

sm

1 Possibilidade de perigo, que ameaça as pessoas ou o meio ambiente.

2 **POR EXT** Probabilidade de prejuízo ou de insucesso em determinado empreendimento, projeto, coisa etc. em razão de acontecimento incerto, que independe da vontade dos envolvidos.

3 **JUR** Incidente que acarreta indenização, em contratos de seguro.

4 **JUR** Em situação de risco, responsabilidade sobre a perda ou o dano.

- Essas são as definições do dicionário Michaelis (2024) para “Risco”;
 - Observe a definição “2” e “4”.
- De forma geral, a **PROBABILIDADE** de **PREJUÍZO** em razão de **ALGO** ou **ALGUÉM**;
- Especificamente em S. I., podemos dizer que essa “Probabilidade” é composta por **3 Fatores** e **1 Razão**.



INSTITUTO
FEDERAL
São Paulo

Câmpus
Catanduva



1º Fator - Vulnerabilidades

Vulnerabilidades



- O que é uma Vulnerabilidade?
 - Segundo a ISO 27002, é a “**Fragilidade** de um ATIVO ou grupo de ATIVOS que pode ser **explorada** por uma ou mais **Ameaças**”;
- Porém, ainda não vimos a definição de “Ameaças”, então em termos mais simples como vocês definiriam “Vulnerabilidade”?
- Qualquer **fraqueza** que possa ser utilizada para **comprometer** a segurança de **sistemas** ou **informações**;
 - Ou seja, que comprometa pelo menos 1 das 3 **Propriedades da Informação**;

2º Fator - Ameaças

```

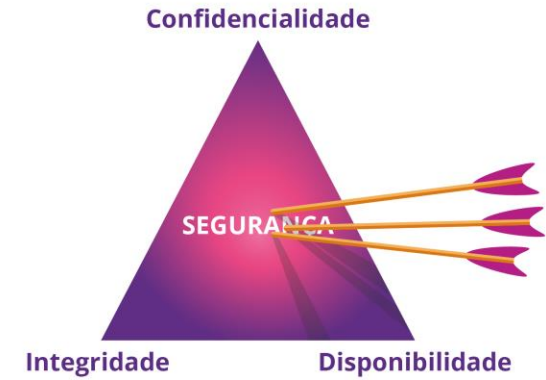
11:01:34Z"window._satellite.container.split("<div>
settings:{path:"turbine
a-user.postcode":pag
"/src/lib/dat
/dataElement
"/src/lib/d
(VV))?(apps
code.js",
e.js",sett
settings:
ta.product
src/lib/da
case 1:re
case 2:
return""
PageLoadTime :modulePate
timing&&window .performance.c
Products&Saving Amount":{modu
savingsAmount"},"tools Produc
!=pageData.products&"unde
Do
(pageD
:sourceif
/checkout/
try{return
};&&"undefined"=type
"undefined"=type
ckout/finish/"
order","o").repla
("savingsAmount"
"newsLetter","rN
id:pageData.order
replace("couponValues","cVs").replace("savingsAmount"

```

- 
- INSTITUTO
FEDERAL**
São Paulo
- Câmpus
Catanduva

Ameaças

- Já que uma **Ameaça** pode comprometer a **Confidencialidade**, **Integridade** e **Disponibilidade** da Informação, podemos deduzir que não são apenas invasões de redes e computadores que são Ameaças.
 - Exemplos?
 - Indisponibilidade por **falta de energia** também é uma ameaça, mesmo ela não sendo intencional;
- Ou seja, cabe à Segurança da Informação prover mecanismos para impedir que as **Ameaças** explorem as **Vulnerabilidades**;



Ameaças

- Basicamente, existem 3 tipos de **AMEAÇAS**:
 - **Ambientais** (ou Naturais): causados por fenômenos da natureza.
Exemplos?
 - **Ex**: enchentes, vendavais, periquitos, etc.
 - **Deliberadas** (ou Intencionais): quando à intenção de causar danos. Exemplos?
 - **Ex**: sabotagem, furto, vandalismo, malware, etc.
 - **Acidentais** (ou Involuntárias): quando NÃO à intenção, comumente ocorrem por negligência. Exemplos?
 - **Ex**: acidentes, falha humana, falta de capacitação, etc.





A Razão – Medidas de Segurança

Medidas de Segurança

- “São as **práticas**, **procedimentos** e **mecanismos** usados para a **proteção da informação** e seus **ativos**, que podem **impedir** que **ameaças** explorem **vulnerabilidades**.” (SÊMOLA, 2014);
- Mas nas palavras de vocês, o que são “Medidas de Segurança”?
 - São **meios** para **eliminar** as vulnerabilidades e conseqüentemente, **neutralizar** a **Ameaça**;
- É importante notar que ao **ELIMINAR** uma vulnerabilidade, ou **REDUZIR** o seu impacto, os **Riscos** são minimizados;



Medidas de Segurança

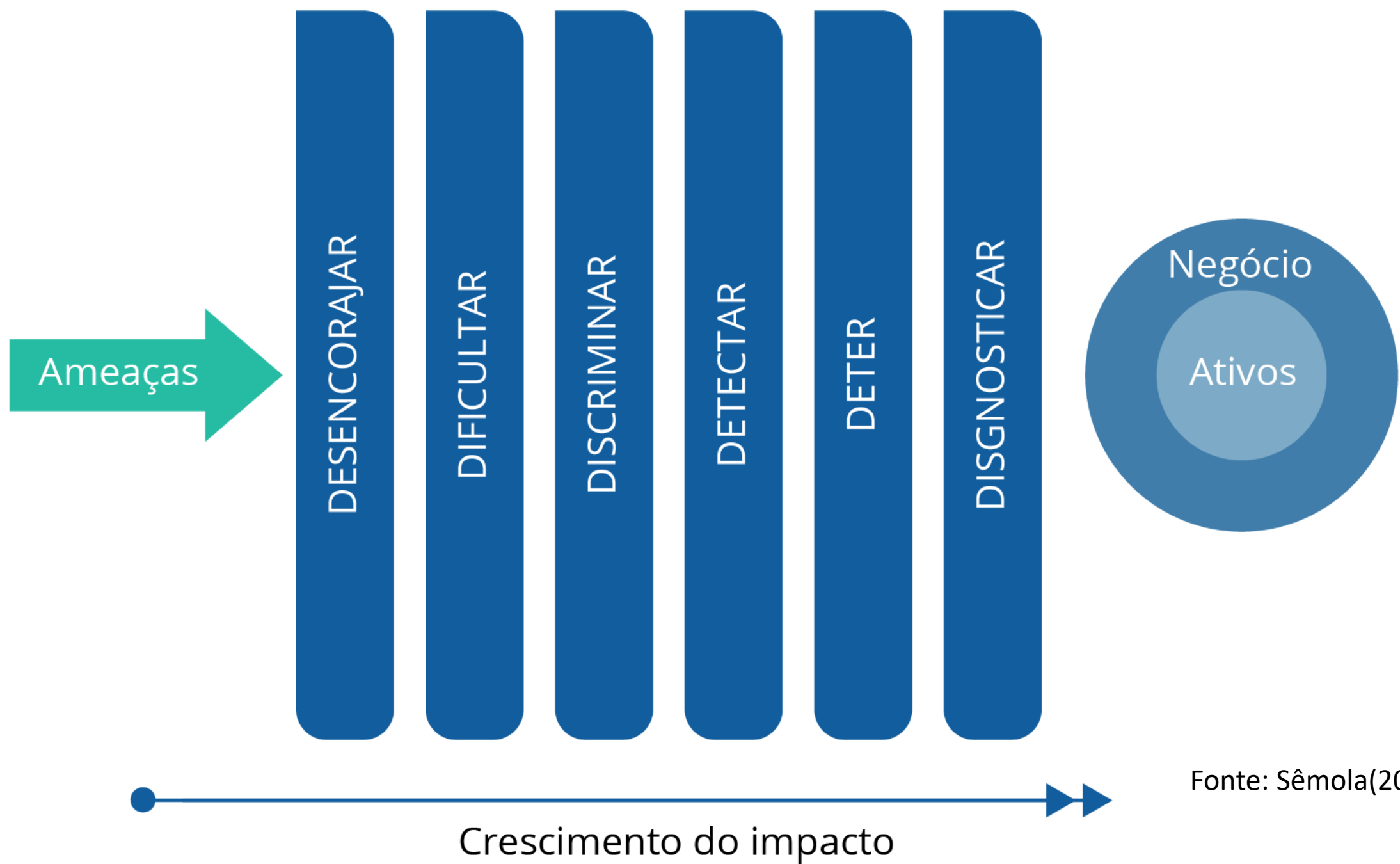
- É **vital** entendermos que nem sempre uma **Medida de Segurança** é implementada, isso acontece principalmente quando seus **custos** são muito **elevados**, inclusive ultrapassando o valor da perda causada pela **exploração da Vulnerabilidade**;
 - Com isso em mente, muitas das vezes **assume-se o risco** ou reduz o **impacto** (financeiro) através da contratação de um seguro por exemplo.
- Também é importante notar que os **desafios** vão muito além das **Medidas**, **Vulnerabilidades** ou **Ameaças**, como está ilustrado na imagem a seguir;



Medidas de Segurança - Barreiras

- Dada a amplitude e complexidade da Segurança da Informação, Sêmola (2014) propõe que as **Medidas de Segurança** sejam estudadas em **6 diferentes Barreiras**;
- Todas tem o objetivo de **reduzir os Riscos**, mas devem **estar perfeitamente Integradas para esse objetivo**;

AMEAÇAS	
1ª BARREIRA	DESENCORAJAR
2ª BARREIRA	DIFICULTAR
3ª BARREIRA	DISCRIMINAR
4ª BARREIRA	DETECTAR
5ª BARREIRA	DETER
6ª BARREIRA	DIAGNOSTICAR
ATIVOS	



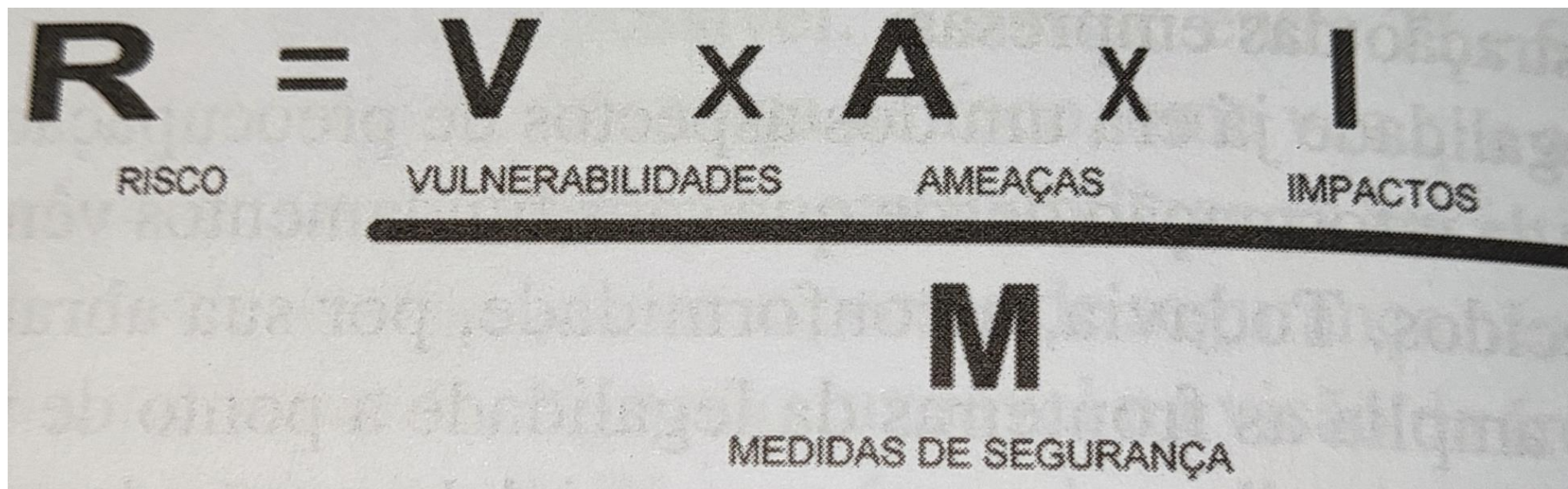
Fonte: Sêmola(2014)



Equação do Risco

Equação do Risco

- Dadas as informações e definições, Sêmola(2014) expõe a seguinte equação para mensurar o Risco;



The diagram illustrates the Risk Equation as a mathematical formula. It features large, bold letters for the variables and smaller text for their definitions. The equation is structured as follows:

$$R = V \times A \times I \div M$$

Below the letters, the corresponding terms are listed:

- R** is labeled **RISCO**.
- V** is labeled **VULNERABILIDADES**.
- A** is labeled **AMEAÇAS**.
- I** is labeled **IMPACTOS**.
- M** is labeled **MEDIDAS DE SEGURANÇA**.

A horizontal line is drawn under the terms VULNERABILIDADES, AMEAÇAS, and IMPACTOS, indicating that these three components are multiplied together and then divided by MEDIDAS DE SEGURANÇA.

Equação do Risco



- É importante notar que SE não tivermos **Vulnerabilidade**, não temos **Risco**;
- O mesmo vale para as **Ameaças** e os **Impactos**;
 - Qual o **Risco** de uma **Vulnerabilidade** que não causa impacto **NENHUM** para a empresa?
- Também vale notar que pelas **Medidas de Segurança** serem FATOR na Equação, por maiores que sejam as Medidas e menores que sejam as **Vulnerabilidade**, **Ameaças** e **Impactos**, o Risco tenderá a 0 mas **NUNCA** será 0;
- É preciso entender que existem **Riscos Desconhecidos**, e que as **Ameaças Deliberadas** sempre procuram maneiras de contornar as **Medidas de Segurança**;



Malwares

Malwares



- Malware vem da **abreviação** do termo “Software Malicioso” em Inglês, **Malicious Software**;
- São programas que **executam ações danosas e maliciosas**, além de serem utilizados como intermediários para prática de Golpes, realização de Ataques e envio de Spam;

Malwares



- Eles são capazes de **infectar** diversos tipos de **dispositivos**, além de assumir diversas formas;
- Eles costumam **explorar vulnerabilidades** existentes, ou **criar** uma **vulnerabilidade** para ser explorada por outro Malware ou um Atacante;

Malwares - Tipos



- Existe uma variedade de **Malwares**, **definidos** de acordo com sua **função** e ação;
- Conhecer suas **características** nos **auxilia** a **detecta-los** e corrigi-los;
 - Também permite estimar o tipo de dano e a abrangência dele.

Malwares – Vírus

- É um **pedaço de código** capaz de se integrar a Programas e Arquivos;
- Esse código é **executando** juntamente com o Programa/Arquivo infectado;
- O Vírus fica **inativo** até a abertura do Programa ou Arquivo infectado;



Malwares – Vírus

- Após executado ele poderá se **propagar** através dos **sistemas**, **mensagens** e **e-mails**, além das demais rotinas programadas para sua execução;
- Apesar de não ser popular na atualidade, seu nome é utilizado **erroneamente** como sinônimo de Malware (Código Malicioso);



Malwares – Ransomware



- Esse tipo de Malware é capaz de tornar todo o **sistema operacional** e/ou **armazenamento** de arquivos do dispositivo **inacessível** através de criptografia;
- Após a infecção, ele irá **pedir resgate** para lhe devolver os dados ou não vaza-los;

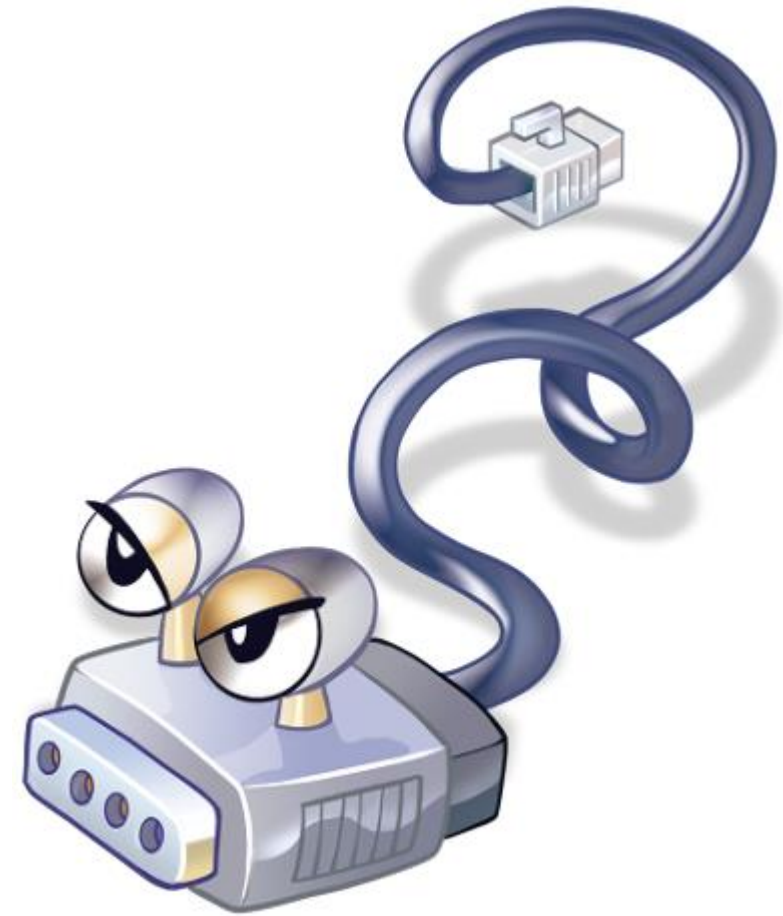
Malwares – Ransomware



- O dispositivo infectado exibirá uma mensagem com os procedimentos necessários para **realizar** esse **pagamento**;
- Nesses procedimentos estão, além do **valor**, o **prazo**, a **identificação** do dispositivo e até a forma de contato com o Atacante.

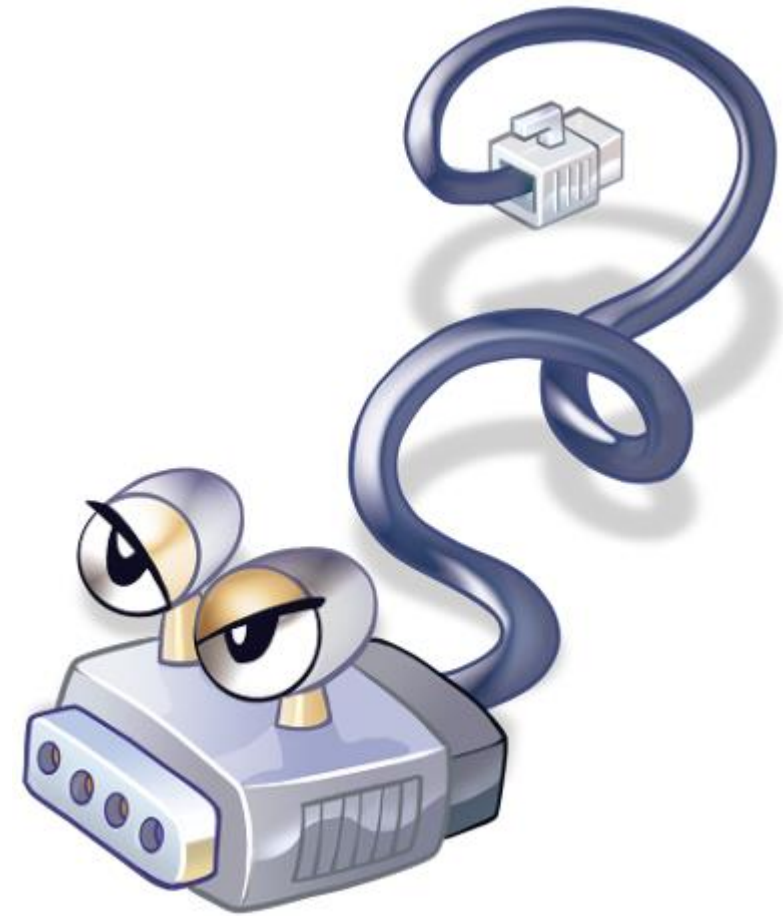
Malwares – Worm

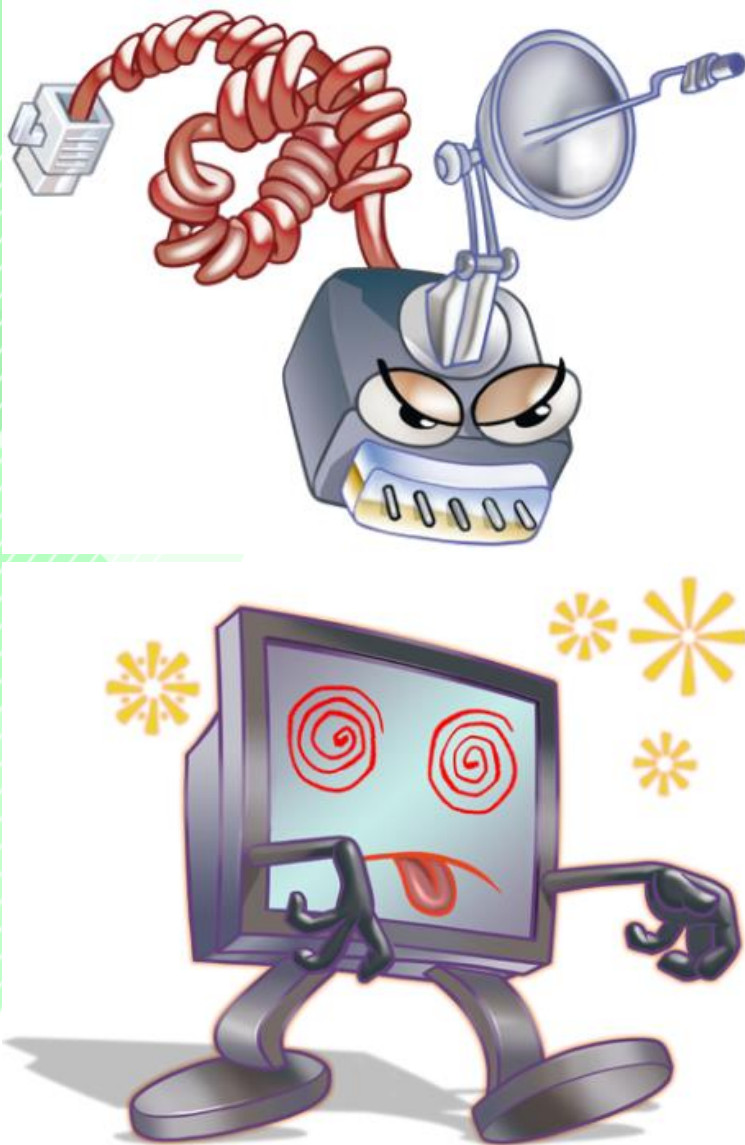
- É um **programa independente**, capaz de se **replicar** e **infectar** outros dispositivos sem exigir ação de ninguém;
- São comumente capazes de **detectar vulnerabilidade** em sistemas e dispositivos da rede e usa-las **para** sua **disseminação**;
- São frequentemente **usados** para execução de “**carga útil**”, ou seja um código criado para danificar um sistema;



Malwares – Worm

- Essa “carga útil” é capaz de excluir arquivos, criptografar dados para um Ransomware, roubar informações, etc;
- Também pode ser responsável pelo consumo excessivo de recursos computacionais, o que afeta o desempenho de redes e dispositivos;





Malwares – Bot

- Similar ao Worm, **alta capacidade de replicação**;
- Porém, esse possui **capacidade de comunicação** com o Atacante que o disseminou;
- Essa comunicação acontece para que o Atacante possa ter **controle remotamente**;
- O dispositivo infectado por esse Malware é chamado de Bot ou **Zumbi**;

Malwares – Botnet

- É uma **rede formada** por dispositivos **Zumbis**;
- Quanto **maior a quantidade de Zumbis**, e suas capacidades de conexão e processamento, **mais forte será a Botnet**;
- Exemplo de funcionalidades:
 - DDoS, Propagação de Malware, Coleta de Informações Pessoais, Envio de Spam, Mineração de Criptomoeda, etc;

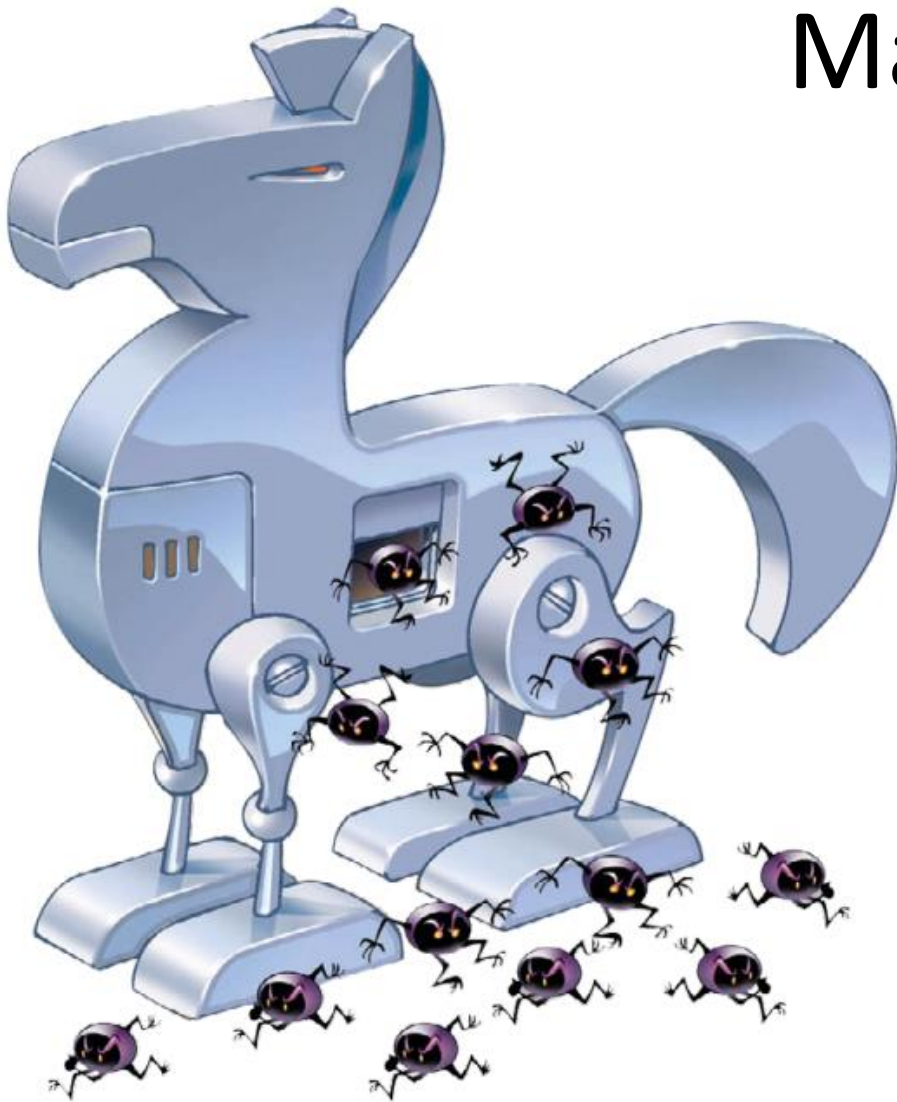


Malwares – Trojan



- Seu nome vêm da **mitologia grega**, onde na guerra de Tróia os gregos fingiram se render e entregaram aos Troianos um “presente”.
- Um **cavalo gigante** feito em madeira e cheio de soldados Gregos, que ao anoitecer abriram os portões da cidade de Tróia permitindo a invasão e dominação grega;

Malwares – Trojan



- Paralelo à mitologia, o **Trojan** é um software que **aparentemente cumpre com as funções** para o qual você o instalou;
- **Porém**, ele também **executa atividades maliciosas** das mais variadas através de sub-rotinas ou instalação de outro Malware;



Propagação

Propagação

- A forma de **propagação** de um Malware é tão **importante** quanto o **dano** que ele pode causar, já que a sua capacidade de replicação **potencializa** o **Impacto**;
- E sua **interrupção** pode **evitar** que a infecção atinja **seu objetivo**, como um processo específico dentro de uma empresa;
- Como observado, existem algumas **formas de propagação**, comuns em todos (ou na maioria) dos Malwares;



Propagação



- **Email:** Com um **e-mail comprometido**, um Malware pode forçar o dispositivo a **enviar e-mails** com links e/ou anexos **infectados**. Quando o destinatário abrir esse link/anexo, seu computador será infectado e o ciclo se reinicia;



- **Meios Físicos:** **Pendrives** são a forma mais comum de meio físico utilizado para propagação. Muitas vezes, **ao plugar** o dispositivo infectado em um novo computador, o **Malware** já é capaz de **infectar** e se **propagar** pelo novo Sistema Operacional. **Ex:** Autorun.exe;



Prevenção

Prevenção

- O CERT.BR (2023) também dá algumas **recomendações** de prevenção:
 - Baixe programas e aplicativos apenas de lojas oficiais:
 - Isso irá reduzir a probabilidade de instalar um aplicativo falso ou com um Malware inserido em seu código fonte. **A lojas oficiais detectam e bloqueiam aplicativos inseguros** com maior rapidez. **Ex:** uTorrent.
 - Tenha uma rotina de Backups:
 - Isso **reduz o Impacto de um Malware** que exclua ou bloqueie seus arquivos;



Prevenção

- O CERT.BR (2023) também dá algumas **recomendações** de prevenção:

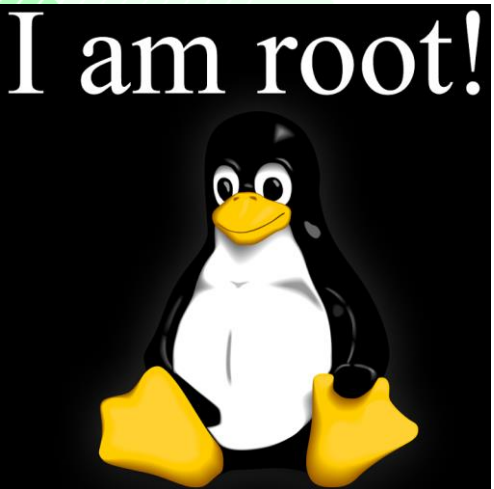
- Utilize Autenticação Forte:

- Um exemplo é a **autenticação de dois fatores**, ela evita que mesmo com o roubo de sua senha um Atacante consiga acessar sua conta de e-mail por exemplo.
- Também é interessante **não repetir senhas**, já que o vazamento de uma pode levar à exposição em vários Apps;
- **Nunca salvar senha no navegador**, justamente por existirem Malwares que conseguem interceptá-las;



Prevenção

- O CERT.BR (2023) também dá algumas **recomendações** de prevenção:



- Use a conta de Administrador apenas quando necessário:
 - O privilégio de acesso de um Malware é o mesmo do usuário que o ativou, ou seja, se a sua conta de usuário for restrita o Malware não será capaz de danificar arquivos de sistema, instalar ou desinstalar softwares, etc;
 - Esse é o Princípio o “**Privilégio Mínimo**”, ter acesso a somente o que é necessário.



Hackers

Hackers



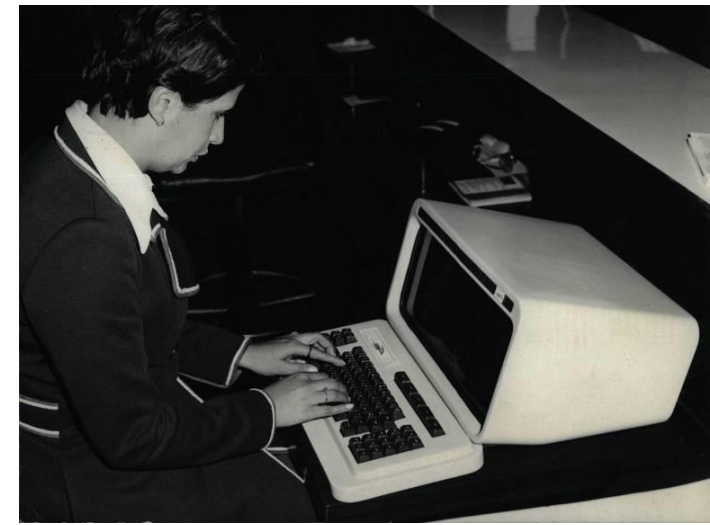
- O que é um Hacker?
 - Hacker é um termo genérico que cobre todos os diferentes perfis de pessoas com profundos (ou nem tanto) conhecimentos de informática (Hardwares e Softwares), que podem ou não utilizar esse conhecimento para cometer crimes.
- Normalmente a mídia se refere a “Hacker” como um criminoso, mas na realidade esse termo abrange MUITO mais que apenas os criminosos;



Hackers – As 5 Gerações

As 5 Gerações

- A evolução dos Hackers se deu em **5 Gerações**, a **1ª** delas foram os “**Programadores Ninja (1960s)**”;
 - Essa geração se deu a partir das **Universidades de Stanford e MIT**, onde a criação da **ARPANET** impulsionou a busca por conhecimento especializado de pequenos grupos de programadores dessas duas universidades;
 - Foi nessa época que houve a **apropriação do termo “Hacker”** por esses grupos;



As 5 Gerações

- A 2ª Geração (1970s) ficaram conhecidas como “Revolucionários”;
 - Ela foi composta e impulsionada por “Gênios” que revolucionaram a informática como Bill Gates e Steve Jobs;
 - Que além de transformarem computadores inacessíveis em dispositivos pessoais, precisaram investir e estimular capacitação pessoal para os trabalhos especializados;
- A Série “Halt and Catch Fire” mostra o surgimento dos PCs e criação de algumas grandes companhias;



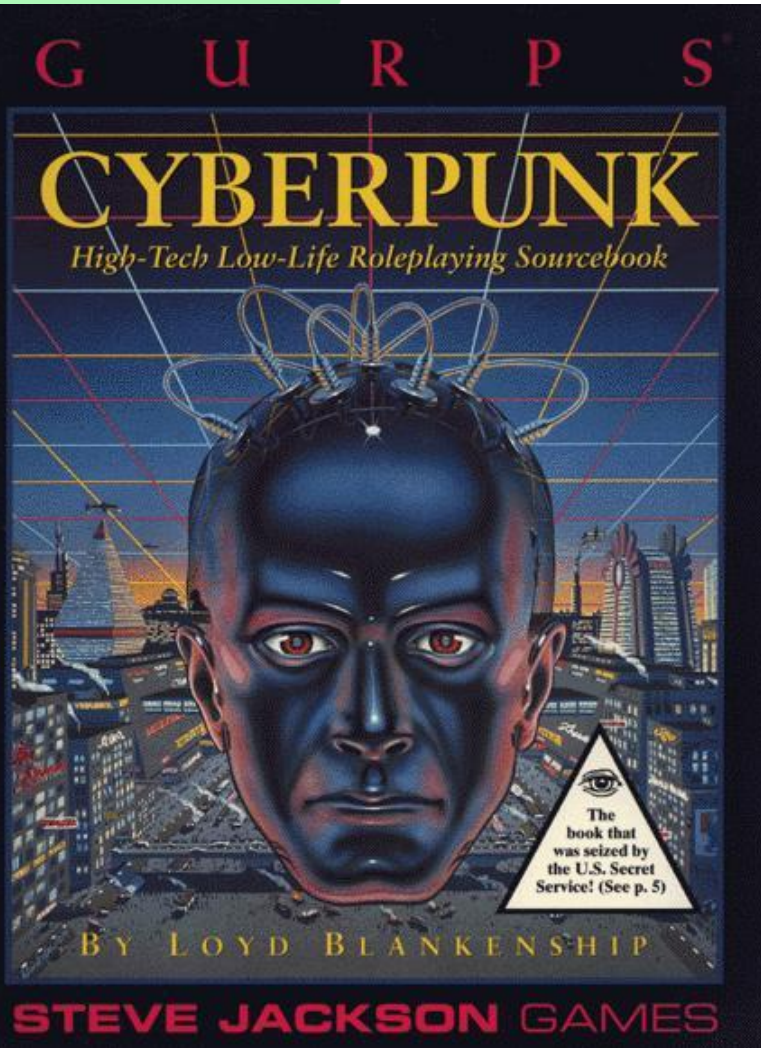
As 5 Gerações

- Já a 3ª Geração ficou conhecida como “Players (1980s e 1990s)”;
 - Extremamente ligada à computação pessoal, ou seja, àquilo que os “Revolucionários” criaram;
 - Foi inicio da conectividade doméstica, e deu grande acesso à esse público;
 - Com essa conectividade doméstica começou a aparecer cada vez mais “Hackers” ou entusiastas;



As 5 Gerações

- Já a 3ª Geração ficou conhecida como “Players (1980s e 1990s)”;
 - Com a **aglomeração em grupos**, foi nessa época que houve as primeiras “**Guerras Hackers**”. Inicialmente sem crimes, mas com muita **discussão e amostragem de conhecimento/poder**;
 - Em 1988 o Governo Americano fez a **primeira grande operação** por causa das “Guerras Hackers”, onde muitos foram presos.





Hackers - Taxonomia

Taxonomia

- Dadas as diferentes Gerações, Chiesa (2008) fornece algumas **Classificações** (Taxonomias) quanto aos **diferentes tipos de Hacker**;
- Essas diferenças são graças a diferentes **motivações** do Hacker;
 - Só pela brincadeira ou para vazamento de Dados;
- E também pelo seu **nível de conhecimento ou especialidade**;
 - Iniciante ou profissional? Ou até mesmo um especialista em código;



Script Kiddies / Lammers

- São **novatos** na atividade de “hackear”, até mesmo entusiastas;
- Normalmente utilizam **ferramentas prontas** para realizar seus ataques;
 - Essas ferramentas costumam ser simples e “intuitivas”, justamente para serem utilizadas pelos iniciantes;
- Apesar do baixo nível de conhecimento, **são muito perigosos já que não sabem os danos que podem causar** com as ferramentas que utilizam;
 - **Ex:** Em 2015 um garoto de 15 anos foi detido no Reino Unido por roubar dados da TalkTalk Telecom.

```
<script type="text/javascript">  
  function getInspiration() {  
    if (morningDay == "depressed")  
      start.Coding & get.Awesome;  
  }  
</script>
```

Crackers / Black Hat



- Possuem **ótimas habilidades** computacionais já que são capazes de **criar seus próprios ataques**;
- Também possuem **intenção criminosa e comportamento malicioso**, até mesmo na sua vida real;
- Podem possuir ódio de alguma empresa ou organização ao ponto de **cometerem fraude** contra essa empresa e até mesmo quererem **vingança**;
- Possuem **grande atenção da mídia**, já que normalmente a mídia nomeia de Hacker quando na realidade o correto seria Cracker.
 - **Ex:** Kevin Mitnick no início da carreira (Filme “Caçada Virtual”).

<https://www.uol.com.br/tilt/noticias/redacao/2023/07/23/kevin-mitnick-quem-foi-o-lendario-hacker-que-morreu-na-ultima-semana.htm>

White Hat

- São **profissionais honestos e pesquisadores** do ramo de Segurança da Informação;
- Trabalham na **descoberta de falhas** de segurança para que possam **melhorá-la**;
- A **intenção é sempre proteger os Dados e os Usuários** contra o cibercrime;
- Podem trabalhar em **empresas privadas ou para o governo**;
 - **Ex:** Kevin Poulsen e Kevin Mitnick (fim da carreira).



Gray Hat



- É a **mistura** entre **White e Black Hat**, ou seja, possui ótimo nível de conhecimento;
- **Especialista em vulnerabilidades** (falhas de segurança) dos sistemas e redes, assim como está sempre em busca de novas falhas;
- Normalmente **desenvolve seu próprios programas e técnicas** de invasão;
- Apesar de **não ter a intenção de tirar vantagem**, ele **se permite ultrapassar a linha da “ética”** em prol da diversão e descoberta;
- Comumente **exige correção** das Vulnerabilidades **ou pagamento** para não divulgá-las. **Ex:** Khalil Shreatch.



Esteganografia

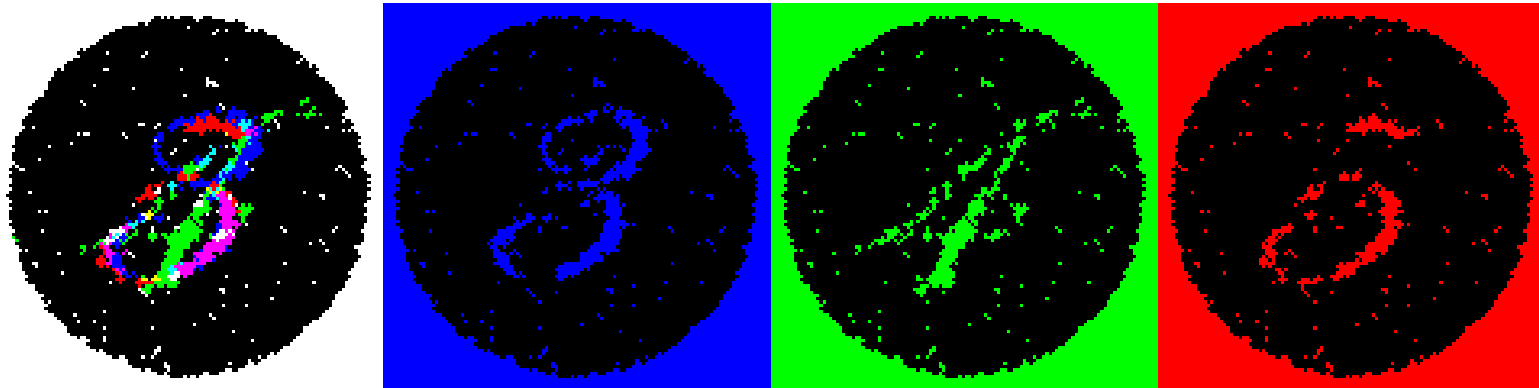
Esteganografia

- O que é Esteganografia?
 - **Steganos** = esconder, ocultar, mascarar;
 - **Grafia** = escrever, escrita;
 - É a arte de esconder mensagens.
- É uma técnica utilizada desde a antiguidade para esconder uma mensagem dentro de objetos, ou até mesmo de outras mensagens;



Esteganografia

- “O objetivo da Esteganografia é ocultar e enganar.” (Stanger 2020);
- É uma forma de **comunicação secreta** e pode envolver o **uso de qualquer meio para ocultar mensagens**;
- **NÃO É Criptografia**: não envolve embaralhar dados ou utilizar uma chave;
 - “Onde a **criptografia é uma ciência** que **permite** amplamente a **privacidade**, a **esteganografia** é uma prática que **permite o sigilo e o engano.**” (Stanger, 2020).



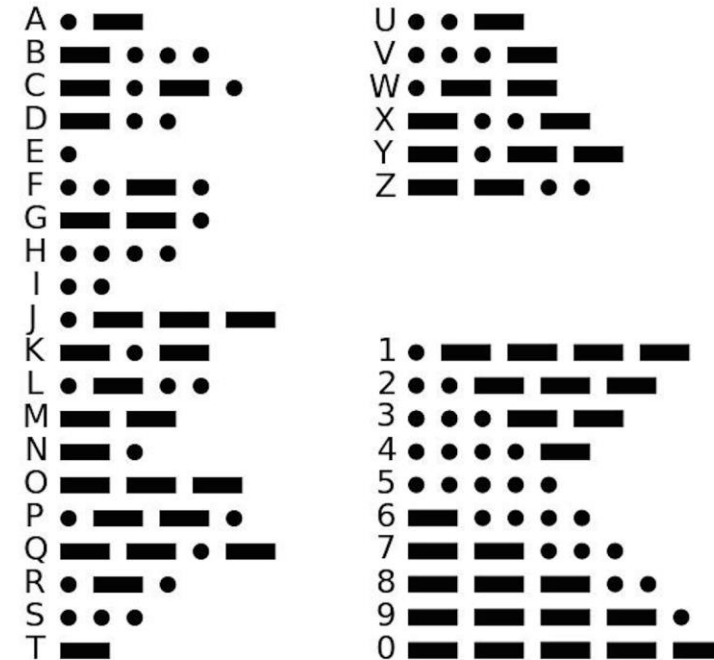
Esteganografia - História

- A esteganografia tem sido utilizada a séculos:
- **Demaratus (rei de Esparta)**, enviou um aviso sobre um **ataque iminente à Grécia**;
 - Ele escreveu uma **mensagem no suporte de uma placa de cera, antes que a cera de abelha fosse aplicada** à ela;
 - Essas placas de cera de abelha eram utilizadas como **superfície de escrita reutilizáveis**.



Esteganografia - História

- A esteganografia tem sido utilizada a séculos:
- **Na 2ª Guerra Mundial, o Tricô** foi utilizado esconder mensagens:
 - **Espiãs britânicas** na Alemanha utilizavam **linhas de seda para “tricotar”** nós específicos que representavam **“pontos” e “linhas” do código Morse**;
 - Essas **linha de seda** tricotadas **eram escondidas em peças de roupa**, ou até mesmo no cadarço do sapato para não serem descobertos;
 - Assim era **possível trocar mensagens sem serem descobertas**.



Esteganografia - História

- A esteganografia tem sido utilizada a séculos:
- **Também na 2ª Guerra Mundial a Cifra Nula foi usada para passar informações dos EUA ao Japão;**
 - A **Espiã Japonesa**, Velvalee Dickinson, em Nova York, enviada rotineiramente **mensagens à América do Sul** com mensagens secretas **contendo informações da Marinha Estadunidense**;
 - Ela era **comerciante de bonecas** e as cartas “discutiam” quantidades e tipos de **bonecas** a enviar;
 - **Porém, escondiam Ordens e Posicionamento de navios Norte-Americanos;**





Aplicações na Computação

Aplicações na Computação

- Em **Computação**, é utilizada para **privacidade** ao enviar informações;
- Ou seja, é utilizado para **esconder mensagens em imagens, vídeos, áudios ou até em um texto**;
- O **emissor insere a mensagem** em um tipo de **arquivo**, aparentemente inofensivo, e que **somente o destinatário poderá extrai-la**.



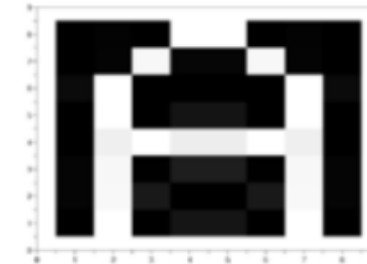
Aplicações na Computação

- Geralmente **utiliza-se uma senha conhecida** entre emissor/receptor, para os processos de camuflagem e extração;
- Se o arquivo for interceptado, não existe indício de mensagem camuflada;
- E mesmo se existir, **não possui a senha, nem a técnica utilizada**;





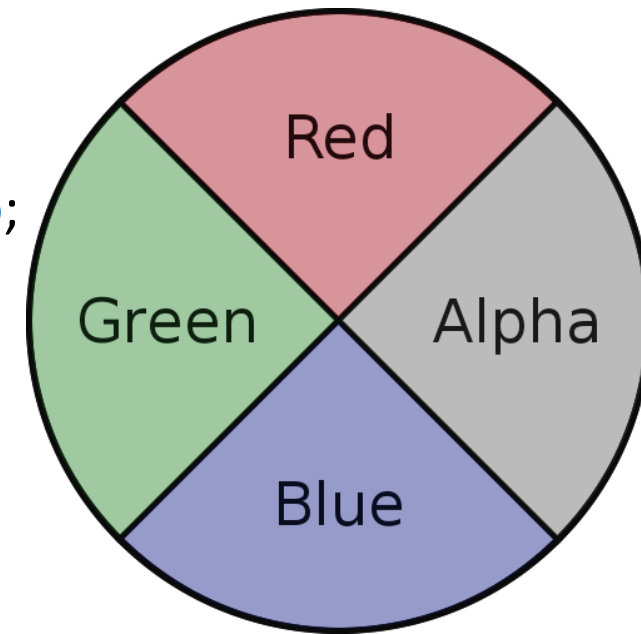
Aplicações na Computação



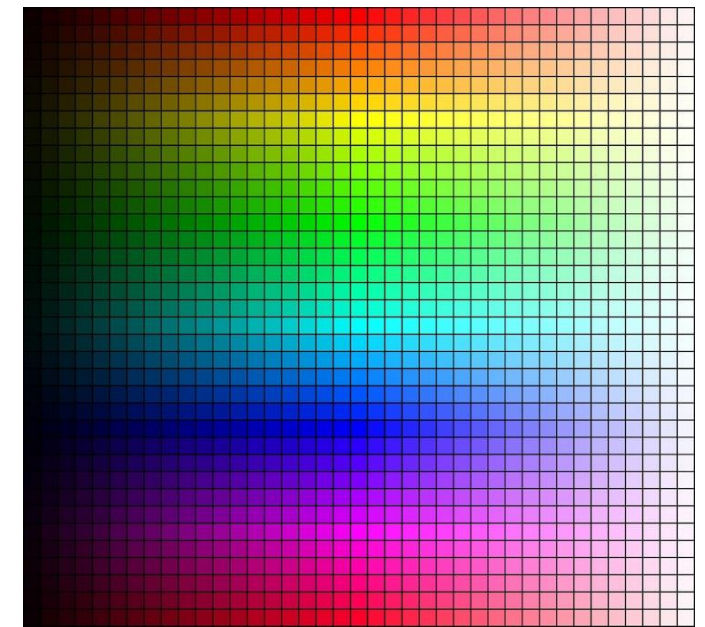
- **Vocabulário:**
 - **Meio de cobertura:** **Imagem** (cover-image), **áudio** (cover-áudio), **texto** (cover-text);
 - **Cover-object:** Um **objeto utilizado como cobertura**;
 - **Stego-key:** **Chave conhecida** para camuflar e revelar a mensagem.
- Uma chave (stego-key) é usada para mascarar os dados na imagem de cobertura (cover-image), o que resulta na estego-imagem (imagem com dados escondidos) a ser enviada;

Técnicas - LSB

- O LSB, **Bit Menos Significativo**, realiza a **inserção de Dados nos Bits Menos Significativos** de uma imagem;
 - É aplicado a cada byte de uma imagem de 32-bits;
 - Ou seja, cada pixel desta imagem possui 4 bytes de tamanho;
 - 1 byte para canal alpha (opacidade) (vai de 0 a 255);
 - 1 byte para canal vermelho (red) (vai de 0 a 255);
 - 1 byte para canal verde (green) (vai de 0 a 255);
 - 1 byte para canal azul (blue) (vai de 0 a 255);
 - Então em cada byte (4 por pixel), é selecionado o bit menos significante para representar o bit a ser escondido.



Técnicas - LSB



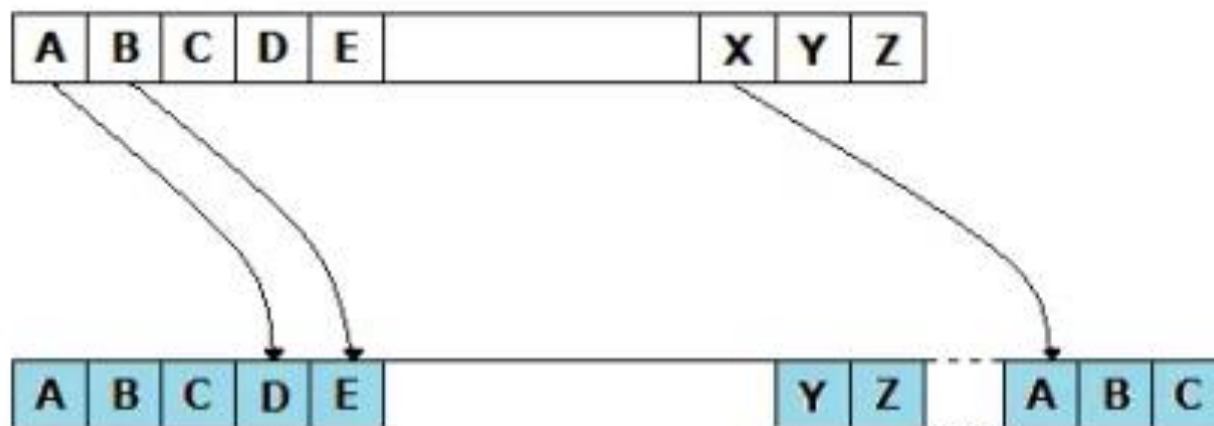
- Qual é o bit menos significativo?
- R: O ÚLTIMO.
- Por Que?
- Porque essas 4 “cores” possuem 256 diferentes intensidades (de 0 a 255 em decimal) e alterando apenas o último bit, essa intensidade se alterará tão pouco que será imperceptível ao ser humano;
- Ex: $255 = 11111111$ -> alterando o último bit temos: $11111110 = 254$



Criptografia

Criptografia

- O que é Criptografia?
 - Ciência ou Arte de escrever mensagens em forma de Cifra ou em Código.
- É o **principal mecanismo de segurança** para se proteger dos riscos associados ao uso da **Internet**;
 - Ela encontra-se integrada, ou pode ser adicionada, à maioria dos sistemas operacionais e aplicações.



Criptografia

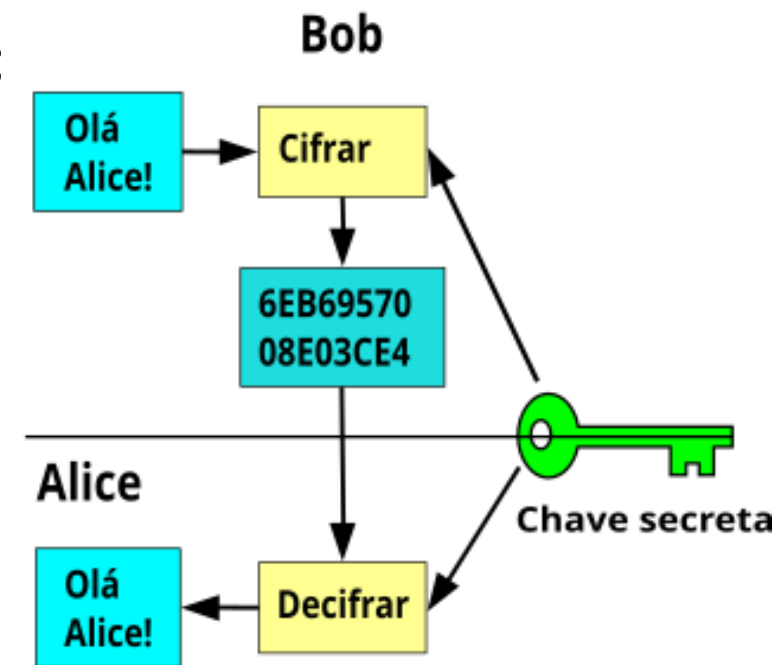
- **Funcionalidades:**
 - Proteger dados sigilosos como **arquivo de senhas ou dados financeiros**;
 - Proteger **arquivos pessoais** através da criptografia automática de uma partição do HD;
 - Proteção **contra acessos indevidos** à contas e sistemas;
 - Proteção durante a **troca de informações** como as realizadas navegando na Internet.



Criptografia de Chave Simétrica

Criptografia de Chave Simétrica

- Também conhecida como **Criptografia de Chave Secreta** ou de Chave Única;
 - Utiliza a **mesma chave para Cifrar e Decifrar** informações;
 - Ou seja, **todos precisam utilizar a MESMA chave** para Cifrar/Decifrar a informação.
- Principal uso é **confidencialidade** de informações;
- Porém, **precisa ser previamente combinada** por uma comunicação segura.



Criptografia de Chave Simétrica

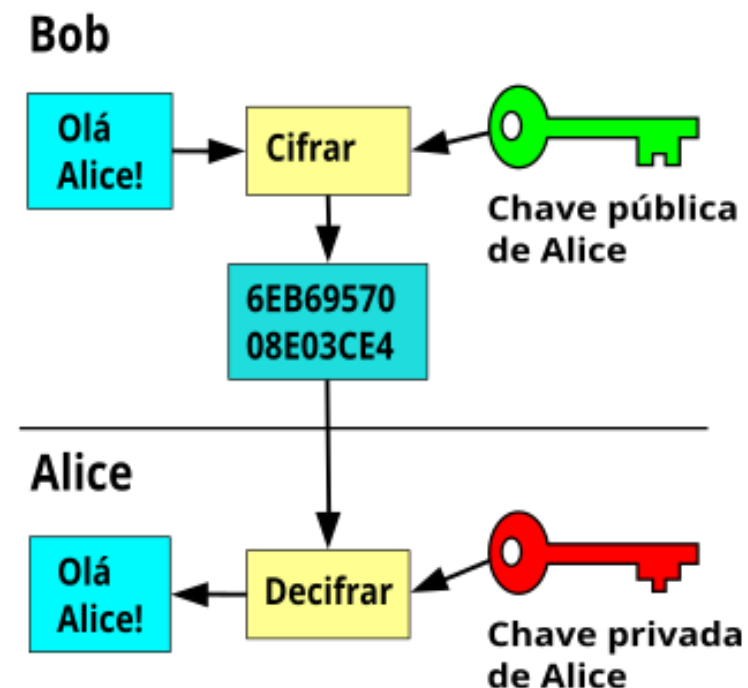




Criptografia de Chave Assimétrica

Criptografia de Chave Assimétrica

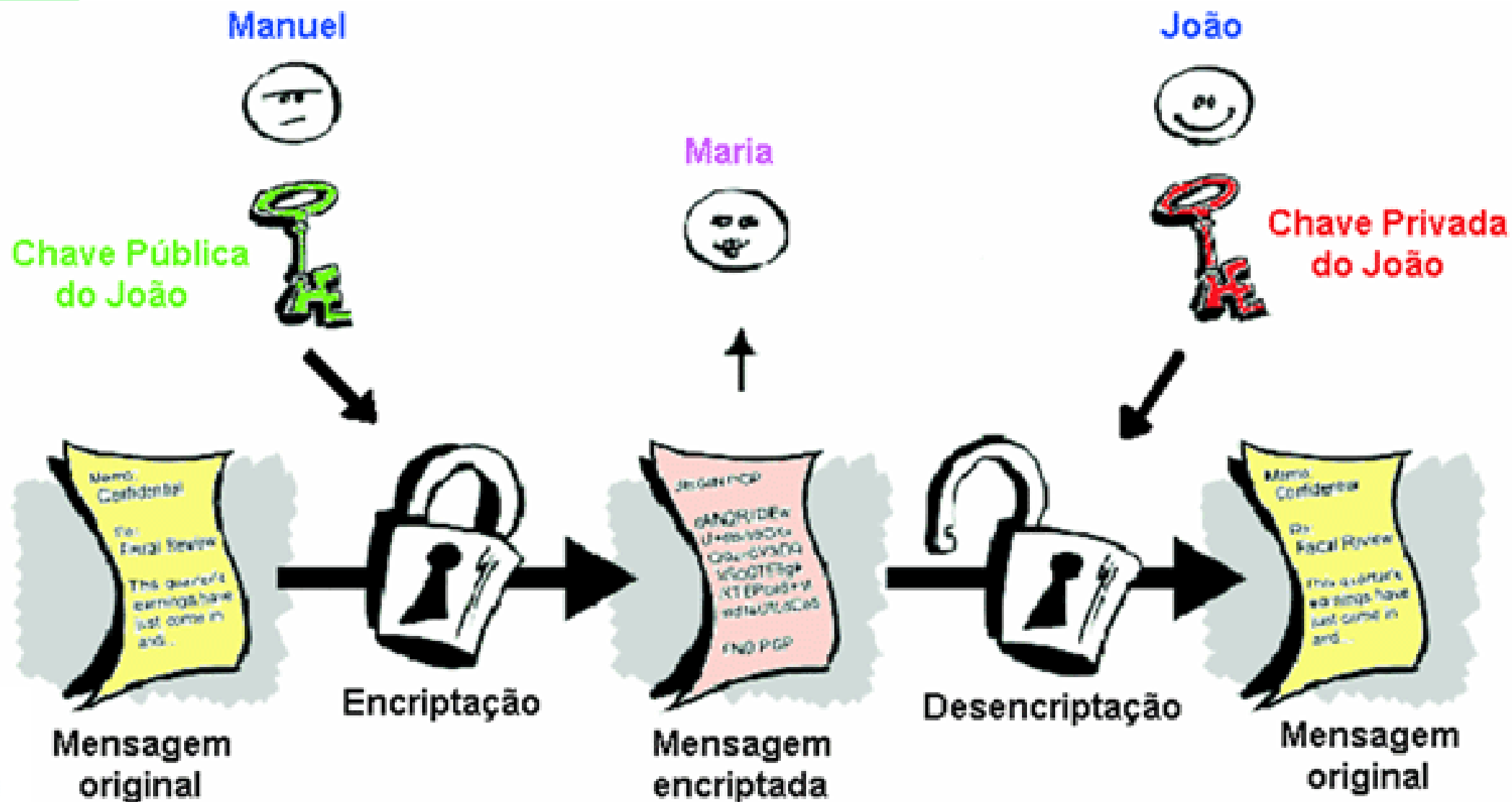
- Também conhecida como **Criptografia de Chave Pública**;
 - **Utiliza 2 chaves** para fazer o serviço;
 - **Chave Pública**: pode ser amplamente divulgada, usada para Cifrar os dados;
 - **Chave Privada**: deve ser mantida em segredo pelo dono, usada para Decifrar os dados;
- Quando os dados são **Cifrados por uma** delas, **apenas a outra pode Decifrar**;



Criptografia de Chave Assimétrica

- A chave usada para CIFRAR irá definir o tipo de proteção aplicado:
 - **Cifrar com Chave Pública:** garante **CONFIDENCIALIDADE**, porque apenas o DONO será capaz de Decifrar;
 - **Cifrar com Chave Privada:** garante **AUTENTICAÇÃO, INTEGRIDADE e NÃO-REPÚDIO**, graças a verificação da chave pública do DONO.
- Possui **processamento mais lento**, porém é **mais fácil de gerenciar** já que não requer manter 1 chave secreta com cada um que desejar se comunicar.

Criptografia de Chave Assimétrica



Segurança Web (SSL/TLS)

Segurança Web (SSL/TLS)

- Já para as demais situações (maioria), temos o **HTTPS**;
 - Que utiliza **protocolos como o SSL e TLS** para fazer a **criptografia**;
- Mas, **SSL e TLS são protocolos de criptografia simétricas ou assimétricas?**



AMBOS

Segurança Web (SSL/TLS)

- Ou seja, ele Criptografa uma Chave SIMÉTRICA com uma ASSIMÉTRICA, garantindo segurança nesse compartilhamento;
- Posteriormente, ambos utilizam a chave SIMÉTRICA (mais rápida) para troca de dados;
- **Ex:** Algoritmo de Diffie-Hellman.

Vídeo: “Diffie-Hellman Key Exchange” (8 min.)

https://www.youtube.com/watch?v=YEBfamv-_do

Segurança Web (SSL/TLS)



Hash Criptográfico (função resumo)

Hash Criptográfico

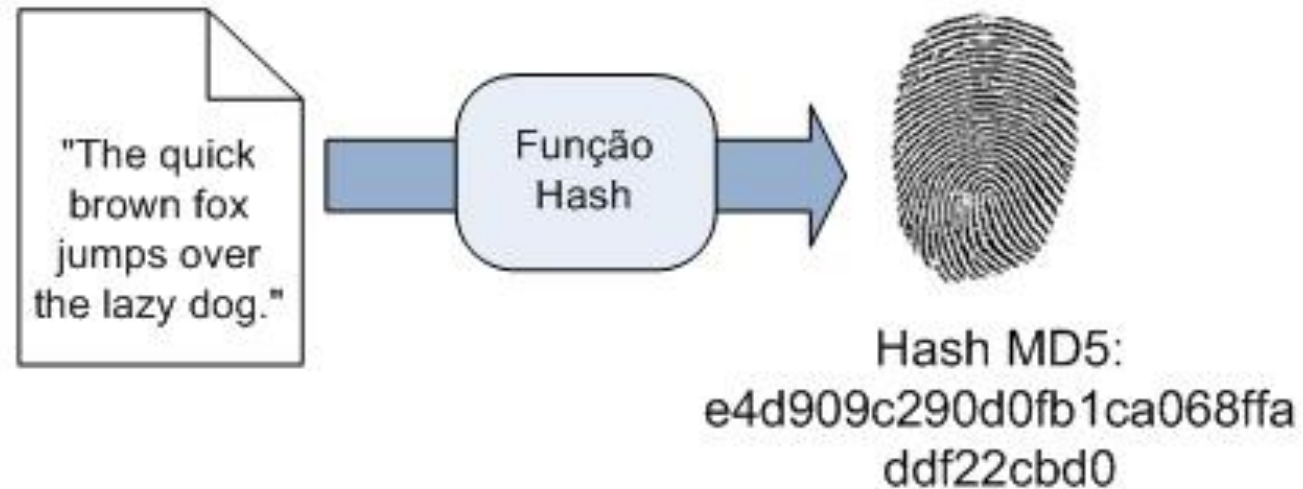
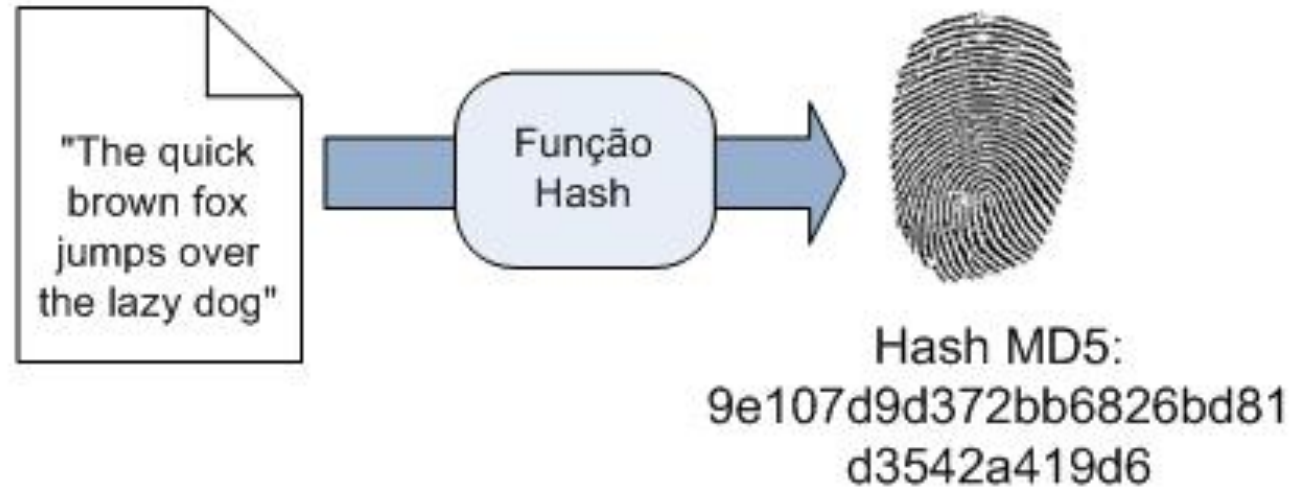
- Hash Criptográfico é uma Função Resumo;
- Pode ser aplicada a QUALQUER INFORMAÇÃO, e gerará um resultado único de tamanho fixo (o Hash);
- Independente do tamanho.



Hash Criptográfico

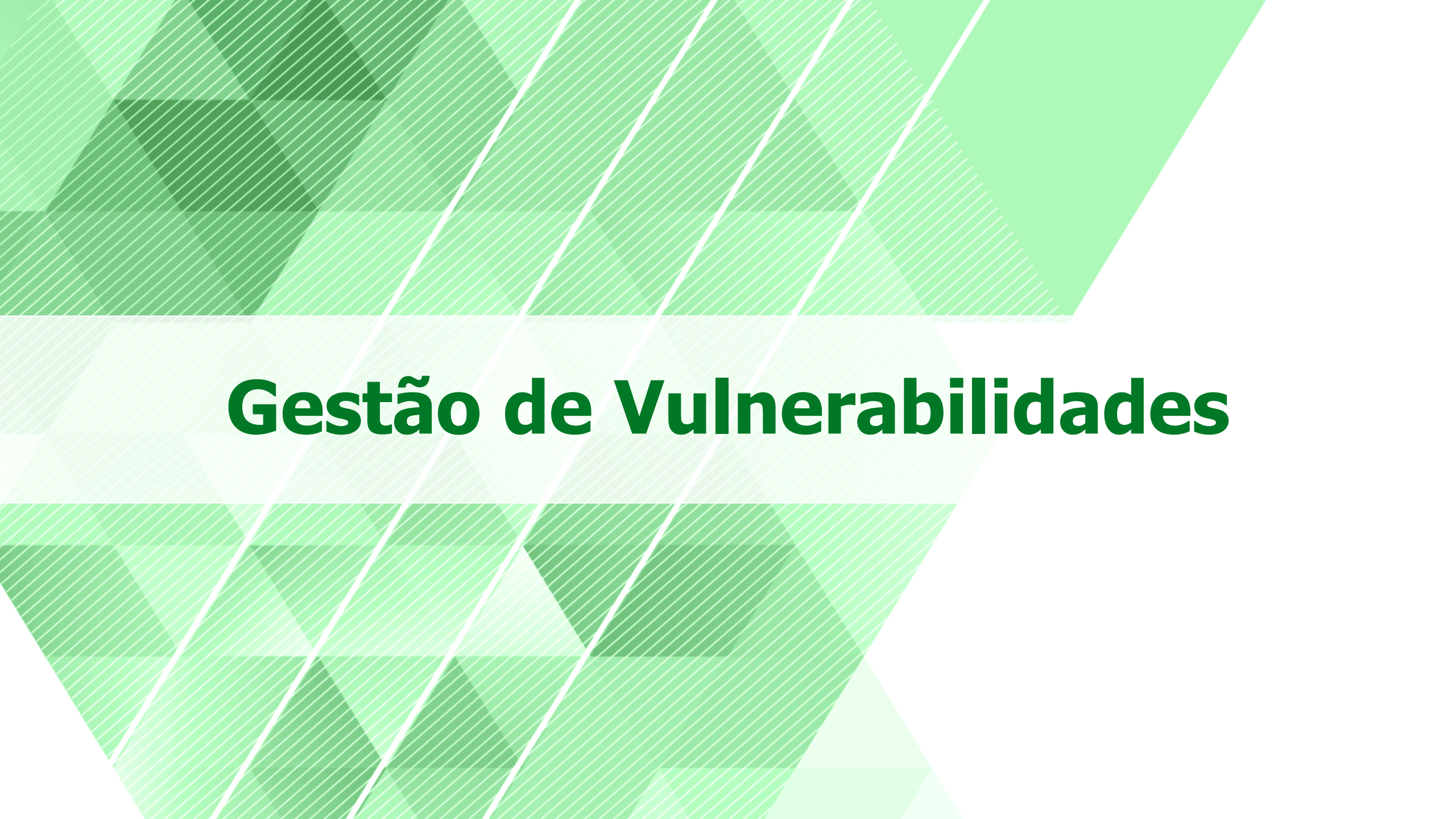
- **É útil em 2 situações:**
 - **Verificação de Integridade:** alguns sites de download disponibilizam o arquivo para download e sua Hash, assim você pode verificar se o arquivo baixado não foi alterado ou corrompido;
 - **Ocultar informações sensíveis:** ao invés de você gravar em um Banco de Dados a senha do usuário, você gera uma Hash e grava ela. Toda vez que a senha precisar ser verificada, o sistema (internamente) irá receber a senha do usuário, gerar a hash e comparar com a salva.

Hash Criptográfico



Hash Criptográfico

- A partir do Hash, NÃO É POSSÍVEL ter a informação original de volta!
 - Ou seja, ele serve para comparação (se a informação que está na sua mão é a mesma que o criador disponibilizou).
- Existem inúmeros algoritmos para gerar Hash, porém alguns não são mais seguros;
 - Isso se deve ao aumento de poder de processamento para ataques de força bruta.



Gestão de Vulnerabilidades

Gestão de Vulnerabilidades

- Inicialmente o MITRE possuía a função de **prestar consultoria para agências governamentais e civis**;
- Em Janeiro de **1999** o MITRE lançou seu primeiro trabalho a fim de catalogar as Vulnerabilidades de Software através de um **White Paper** intitulado “**Towards a Common Enumeration of Vulnerabilities**” / “Em Direção a uma Enumeração Comum de Vulnerabilidades”;

Towards a Common Enumeration of Vulnerabilities

David E. Mann, Steven M. Christey

The MITRE Corporation

202 Burlington Rd., Bedford MA 01730

January 8, 1999

Gestão de Vulnerabilidades

- A partir desse conceito, e dado o sucesso da publicação, o MITRE criou um **grupo de trabalho** para ampliar os estudos e criou o **primeiro CVE List** (Common Vulnerabilities and Exposures List / Lista de Vulnerabilidades e Exposições Comuns), com **321 vulnerabilidades** conhecidas publicamente;

YEAR	VULNERABILITIES	YEAR	VULNERABILITIES
1999	321	2012	5288
2000	1438	2013	5142
2001	1323	2014	7948
2002	1691	2015	6494
2003	1223	2016	6457
2004	1612	2017	14645
2005	6708	2018	16512
2006	6885	2019	17308
2007	7322	2020	18375
2008	5673	2021	20161
2009	5732	2022	25059
2010	4639	2023	28961
2011	4150		

Gestão de Vulnerabilidades

- Em 2006, com a necessidade de uma “organização” mais detalhada e hierarquizada, foi publicado o PLOVER (Preliminary List Of Vulnerability Examples for Researchers / Lista Preliminar de Exemplos de Vulnerabilidade para Pesquisadores);
 - Esse documento lista mais de 1500 vulnerabilidades reais identificadas pelo seu nome CVE;
 - Porém, elas foram organizadas dentro de uma estrutura conceitual e detalhada com base no tipo de fraqueza, comportamento, falhas e defeitos de software;

=====

PLOVER - Preliminary List Of Vulnerability Examples for Researchers

=====

[*] Author: Steve Christey (coley@mitre.org)

[*] Date: March 15, 2006

[*] Document Version: 0.24

Disclaimer: This is a DRAFT document that does not represent an official position of The MITRE Corporation. This document has been created to spur progress in vulnerability classification and vulnerability research.

Gestão de Vulnerabilidades

- O PLOVER foi o primeiro esforço de abstrair, agrupar e classificar as fraquezas comuns das vulnerabilidades;
 - Com base nas sugestões do PLOVER, em 2006 foi lançada a primeira lista CWE (Common Weakness Enumeration / Enumeração de Fraquezas Comuns);
- Different types of security vulnerabilities



Unpatched software



Misconfiguration



Weak credentials



Easy-to-phish users



Trust relationship



Compromised credentials



Malicious insider



Missing/Poor Encryption

The background features a complex geometric pattern of overlapping hexagons in various shades of green. Diagonal white lines intersect these hexagons, creating a sense of depth and movement. The overall aesthetic is modern and tech-oriented.

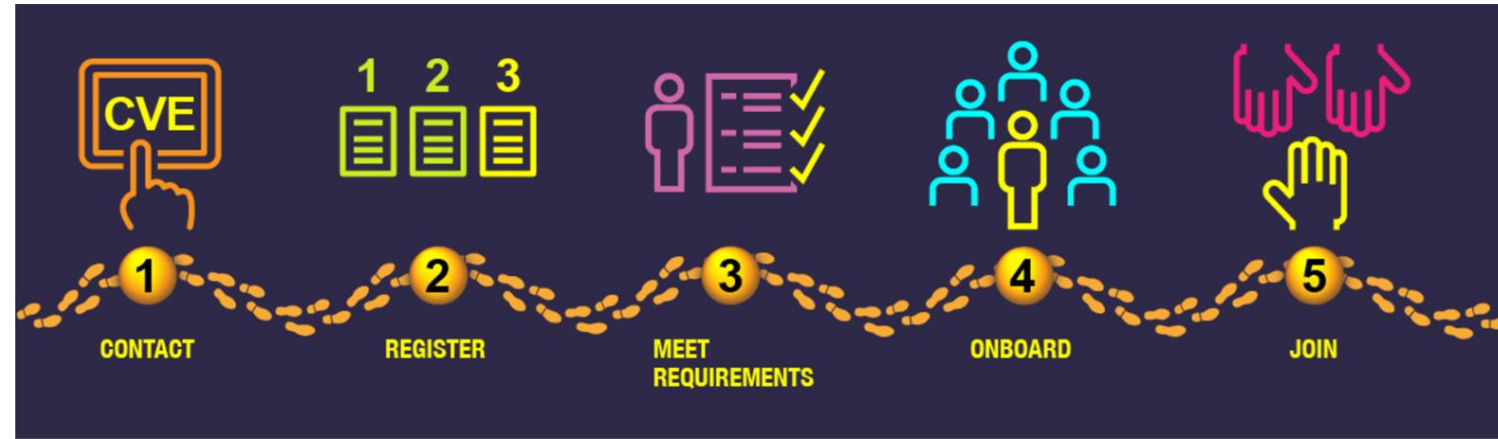
CVE



- A missão do Programa CVE é identificar, definir e catalogar vulnerabilidades de segurança cibernética divulgadas publicamente.
- Há um Registro CVE para cada vulnerabilidade no catálogo.
- As vulnerabilidades são descobertas, então atribuídas e publicadas por organizações de todo o mundo que fizeram parceria com o Programa CVE, as CNAs;
- **Fonte:** <https://www.cve.org/About/Overview>

CVE

- Os parceiros publicam Registros CVE para comunicar descrições consistentes de vulnerabilidades.



- Esses Registros são usados por Profissionais de Tecnologia da Informação e Segurança Cibernética para **garantir que estejam discutindo o mesmo problema** e para coordenar seus esforços para **priorizar e abordar as vulnerabilidades**.
- Fonte:** <https://www.cve.org/About/Overview>



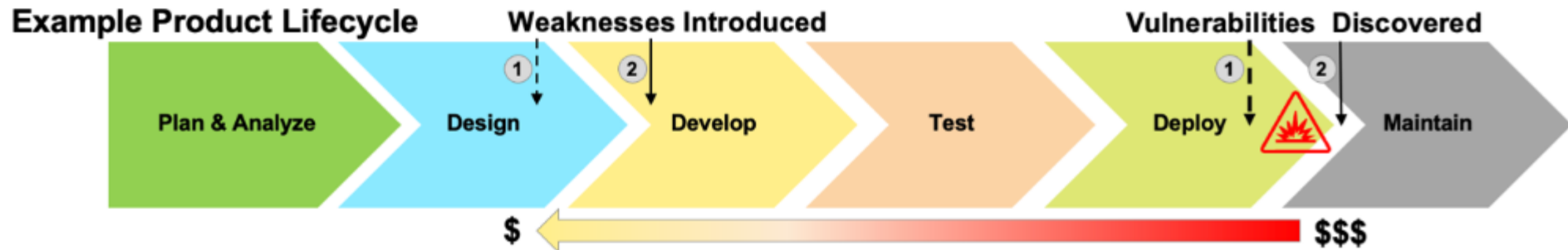
CWE



- A CWE é uma **lista** desenvolvida pela comunidade **sobre fraquezas comuns de software e hardware**. Uma “fraqueza” é uma condição em um software, firmware, hardware ou componente de serviço que, sob certas circunstâncias, pode contribuir para a introdução de vulnerabilidades. **A Lista CWE associa o identificador de classificação que descrevem fraquezas em termos de CWEs.**
- **Fonte:** <https://cwe.mitre.org/about/index.html>

CWE

- Conhecer as fraquezas que resultam em vulnerabilidades significa que desenvolvedores de software, designers de hardware e arquitetos de segurança podem eliminá-las antes da implantação, quando é muito mais fácil e barato de fazê-lo.
- **Fonte:** <https://cwe.mitre.org/about/index.html>





- **CVE** -> **Vulnerabilidade** -> Identifica o “CASO”;
- **CWE** -> dá o tipo de **Fraqueza** que originou o “CASO”;
- Relação N para N;
 - 1 **CVE** (Vulnerabilidade) pode ter **N CWEs** (Fraquezas);
 - 1 **CWE** (Fraqueza) pode dar origem a **N CVEs** (Vulnerabilidade).
- Ao corrigir uma CVE, solucionamos a CWE?

NÃO



OWASP

OWASP

- Seu foco é o trabalho para melhoria da segurança de software de forma abrangente;
- Apoiam projetos de softwares abertos e seguros, desenvolvem comunidades em todo o mundo, além de fornecerem recursos educacionais.



OWASP

- “Somos uma **comunidade aberta** dedicada a permitir que organizações **concebam, desenvolvam, adquiram, operem e mantenham aplicativos confiáveis**. Todos os nossos projetos, ferramentas, documentos, fóruns e capítulos são **gratuitos e abertos** a qualquer pessoa interessada em melhorar a segurança de aplicativos.” (OWASP 2024).

- **Fonte:** <https://owasp.org/about/>



OWASP

- A OWASP possui um projeto chamado de “OWASP Top 10”;
- Esse projeto é um documento de conscientização voltados para desenvolvedores e segurança de aplicativos WEB;
- Ele apresenta 10 categorias de riscos de segurança considerados entre os mais críticos para aplicações Web;



- **Fonte:** <https://owasp.org/www-project-top-ten/>

